ONE-PAGE BRIEF

# Post-quantum cryptography review: corda @ 80033580ecfd

Client: R3 — public repository (passive review) · Source: github.com/corda/corda, commit `80033580ecfd` · Reviewed: 2026-11-06 15:38 UTC · Risk profile: Crypto exchange, custodian or wallet

POST-QUANTUM MATURITY
**Level 0 of 4**
no post-quantum cryptography

FINDINGS
**0** Critical **3** High **6** Medium
**1** Low **0** Info

QUANTUM TIMELINE (MOSCA: X + Y − Z)
Key establishment: 10 + 5 − 8 = 7 → **too late**
Signatures: 10 + 5 − 8 = 7 → **too late**

**Next step:** Inventory where classical public-key cryptography protects long-lived data and keys, and choose the first migration: usually a hybrid TLS key exchange and wrapped keys.

## WHAT MATTERS MOST

| | |
|---|---|
| High<br>QSI-2026-19547 | **Certificate has expired (Corda Node Root CA)**<br>What to do: Renew the certificate and automate renewal (e.g. ACME) with expiry monitoring. |
| High<br>QSI-2026-19549 | **Possible hard-coded secret in core/src/main/kotlin/net/corda/core/CordaOID.kt** preliminary<br>What to do: Move secrets to a secrets manager/environment; rotate the exposed values. |
| High<br>QSI-2026-19556 | **Possible hard-coded secret in…** preliminary<br>What to do: Move secrets to a secrets manager/environment; rotate the exposed values. |
| Medium<br>QSI-2026-19553 | **Quantum-vulnerable ECDSA: transaction and message signing (1 file(s))** preliminary<br>What to do: Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum signature schemes as chains… |

6 more in the full report.

## WHAT THE QUANTUM-VULNERABLE CRYPTOGRAPHY PROTECTS

| Role | Algorithms | What to do |
|---|---|---|
| Medium transaction and message signing | ECDSA | Follow each chain's post-quantum roadmap, avoid public-key reuse, and keep signers ready to add post-quantum… |
| Medium authentication and identity (certificates, tokens, device attestation) | ECDSA, Ed25519 | Keep credentials short-lived and plan ML-DSA certificates, tokens and keys as the ecosystem supports them |
| Medium role not determined | ECDSA, RSA, Ed25519 | Classify each usage, record data lifetimes, and plan migration to ML-DSA (FIPS 204) or SLH-DSA (FIPS 205)… |

Static review of source code and manifests; files analysed: 1117. No requests were sent to the owner's systems.

Full report, content SHA-256: `09dd82bf776b5adb6af7367e5cccfe5b259eb10fde085b2eef6d9bb38f43d5c6`

Full report signature (report.sig.json): Ed25519 key, SHA-256 fingerprint `5b3cf9c9bd0fa54447e2b5dfa7a6bab569bd0c666fa46949599e5c348d17083e`. bundle.sig.json lists the SHA-256 of every file in this bundle and is signed too; verify-bundle checks it offline.

Preliminary findings need confirmation in the code; the full report gives the evidence, the limits of each check and how to re-test.